

EXEMPLU GRATUIT / EDIȚIA 2026

EVALUAREA SECURITĂȚII REȚELEI

Exemplu de raport executiv și tehnic

EVALUARE -> REMEDIERE -> VALIDARE -> DOVADĂ

Organizație fictivă și dovezi tehnice sintetice. Exemplul ilustrează structura raportării, analiza riscului, nivelul de detaliu al remedierii și metoda de validare. Nu reprezintă niciun mediu real de client sau de producție.

weownit.net / Network & Security Consulting

Inginerie de securitate bazată pe risc · Arhitectură · Remediere · Validare

Sumar executiv al evaluării

De la constatări tehnice la risc organizațional și remediere validată.

CONCLUZIA EVALUĂRII

Mediul sintetic prezintă slăbiciuni frecvente privind protecția planului de management, segmentarea rețelei, accesul privilegiat și vizibilitatea de securitate. Riscul principal rezultă din combinația dintre accesibilitate prea largă, expunere privilegiată și monitorizare incompletă.

RISC PENTRU ORGANIZAȚIE

O stație de lucru compromisă din zona utilizatorilor poate crea o cale către controlul privilegiat al rețelei. Accesul est-vest excesiv crește posibilitatea de mișcare laterală, iar jurnalizarea incompletă poate reduce capacitatea de detecție și investigație.

REZULTAT

Exemplul arată cum weownit.net corelează dovezile cu impactul operațional, responsabilitatea pentru remediere, criteriile de validare și riscul rezidual - nu doar cu o listă de constatări.

Context organizațional & active critice

Deciziile de securitate pornesc de la ceea ce susține activitatea organizației.

CONTEXT

ACME Manufacturing este o organizație fictivă cu 250 de utilizatori, sediu central, două filiale, ERP critic, servicii interne, conectivitate la distanță și administrare centralizată a rețelei.

ACTIVE CRITICE

Firewall de perimetru; rețea de management; servere ERP și aplicații; conectivitate VPN; jurnalizare centralizată; identități administrative privilegiate.

OBIECTIVE DE SECURITATE

Disponibilitatea conectivității, integritatea configurațiilor privilegiate, confidențialitatea datelor, separarea zonelor de încredere și trasabilitatea acțiunilor administrative.

Domeniu, ipoteze & metodologie

Un model repetabil de evaluare bazată pe risc.

DOMENIUL EVALUĂRII

Arhitectură, frontiere de încredere, expunere administrativă, segmentare, politici firewall, jurnalizare, acces privilegiat, backup de configurație și capacitate de recuperare.

METODĂ

CONTEXT -> EVALUARE -> ANALIZĂ -> PRIORITIZARE -> REMEDIERE -> VALIDARE -> DOVADĂ

ÎNCREDEREA ÎN DOVEZI

Acest exemplu folosește dovezi SINTETICE / INFERATE. Într-un proiect real, fiecare element este clasificat ca observat, confirmat, inferat sau netestat.

Arhitectură & frontiere de încredere

Unde o zonă cu încredere redusă poate ajunge la control privilegiat.



ZONE DE ÎNCREDERE

Internet / Utilizatori / Servere / Management / Administrare securitate / VPN filială.

OBSERVAȚIA PRINCIPALĂ

Rețeaua de utilizatori poate ajunge la serviciile administrative HTTPS/SSH ale firewall-ului. Această accesibilitate slăbește frontiera de încredere și creează o cale inutilă de la o stație cu încredere redusă către un control privilegiat.

STARE ȚINTĂ

Administrarea este permisă numai din zona de management sau printr-un traseu de acces la distanță aprobat, protejat prin MFA, conturi nominale, privilegiu minim și jurnalizare centralizată.

Registru de riscuri & prioritzare

Prioritizăm scenarii de risc, nu setări izolate.

R-01 - EXPUNEREA PLANULUI DE MANAGEMENT

Probabilitate 4/5 | Impact 5/5 | Risc inerent: CRITIC | Risc rezidual țintă: SCĂZUT

R-02 - ACCES EST-VEST EXCESIV

Probabilitate 4/5 | Impact 4/5 | Risc inerent: RIDICAT | Risc rezidual țintă: MEDIU

R-03 - JURNALIZARE DE SECURITATE INCOMPLETĂ

Probabilitate 3/5 | Impact 4/5 | Risc inerent: RIDICAT | Risc rezidual țintă: SCĂZUT

R-04 - ACCES PRIVILEGIAT FĂRĂ MFA

Probabilitate 3/5 | Impact 5/5 | Risc inerent: RIDICAT | Risc rezidual țintă: SCĂZUT

1	2	3	4	5
2	4	6	8	10
3	6	9	12	15
4	8	12	16	
5	10	15	20	25

F-001 - Planul de management accesibil din zona utilizatorilor

Constatare detaliată - RIDICAT / PRIORITATE 1

CALE DE ATAC

Stație compromisă -> Rețea utilizatori -> Administrare firewall -> Control privilegiat

ACTIV AFECTAT

Firewall de perimetru / plan de management.

OBSERVAȚIE

Serviciile administrative HTTPS și SSH sunt accesibile din rețeaua generală de utilizatori, nu exclusiv prin traseul dedicat de management.

SCENARIU DE AMENINȚARE

O stație de lucru compromisă poate stabili conectivitate către planul de management al firewall-ului. Dacă atacatorul obține credențiale administrative sau exploatează o altă slăbiciune de autentificare, poate ajunge la control privilegiat.

DOVEZI ILUSTRATIVE

Sursă 10.20.10.25 (USER) -> 10.20.100.1. TCP/443 ACCESIBIL; TCP/22 ACCESIBIL. Tip dovadă: SINTETIC.

IMPACT POTENȚIAL

Modificări neautorizate ale politicilor firewall, rutării, VPN sau jurnalizării; întreruperea serviciilor; pierderea integrității controlului.

F-001 - Strategie de control & validare

Previne, limitează, detectează, recuperează - apoi demonstrează rezultatul.

CALE DE ATAC

Stație compromisă -> Rețea utilizatori -> Administrare firewall -> Control privilegiat

PREVENIRE

Rețea dedicată de management; surse administrative aprobate; MFA pentru acces privilegiat; conturi nominale de administrator.

LIMITARE

Administrare bazată pe roluri; principiul privilegiului minim; doar protocoalele necesare; administrare prin VPN/OOB unde este cazul.

DETECȚIE

Jurnalizarea autentificărilor administrative; monitorizarea eșecurilor; auditul schimbărilor de configurație; telemetrie centralizată.

RECUPERARE

Backup de configurație validat; traseu de acces de urgență; procedură de revenire; responsabilitate clară pentru recuperare.

RISC DE IMPLEMENTARE

MEDIU - restricționarea accesului de management înainte de confirmarea unei căi administrative alternative poate produce blocarea accesului. Verifică mai întâi consola/OOB.

DOVEZI DE VALIDARE

Admin aprobat -> HTTPS PERMIS; USER -> HTTPS/SSH BLOCAT; Internet -> management BLOCAT; MFA OBLIGATORIE; schimbările de configurație JURNALIZATE.

RISC REZIDUAL ESTIMAT

SCĂZUT atunci când sursele de management sunt restricționate, MFA și conturile nominale sunt impuse, acțiunile privilegiate sunt jurnalizate și testele negative sunt reușite.

F-002 - Acces est-vest excesiv

Constatate detaliată - RIDICAT / PRIORITATE 1

OBSERVAȚIE

O politică largă din zona utilizatorilor către zona de servere permite mai multe servicii decât sunt necesare pentru funcționarea normală.

STARE CURENTĂ

USER -> SERVER: acces larg / tip ANY.

VALIDARE

Test pozitiv pentru fluxurile necesare aplicației și teste negative pentru servicii de baze de date și management. Verificarea jurnalelor pentru traficul respins.

SCENARIU DE AMENINȚARE

O stație de lucru compromisă poate sonda sau accesa servicii interne care nu sunt necesare rolului utilizatorului, crescând numărul de ținte accesibile și impactul potențial.

STARE ȚINTĂ

USER -> APP: doar serviciile necesare. USER -> DB/MGMT: blocat în lipsa unei justificări explicite.

RISC REZIDUAL

MEDIU după aplicarea principiului privilegiului minim și a monitorizării, în funcție de dependențele aplicațiilor și excepțiile aprobate.

Roadmap de remediere & dovezi de închidere

Transformăm constatările în acțiuni măsurabile, asumate și verificabile.

0-7 ZILE

Limitează expunerea privilegiată: restricționează accesul la management, verifică accesul de urgență, impune MFA și desemnează responsabili.

0-30 ZILE

Reduce încrederea inutilă: înlocuiește accesul prea larg utilizator-către-server cu fluxuri aprobate și validează dependențele înainte de aplicare.

30-60 ZILE

Consolidează vizibilitatea și recuperarea: centralizează telemetria relevantă, verifică retenția auditului, testează restaurarea configurației și clarifică responsabilitatea pentru recuperare.

CRITERII DE ÎNCHIDERE

DESCHISĂ -> REMEDIERE PLANIFICATĂ -> IMPLEMENTATĂ -> VALIDARE NECESARĂ -> VERIFICATĂ -> ÎNCHISĂ.

PACHET DE DOVEZI

Extras relevant de configurație, schimbare aprobată, teste pozitive și negative, dovadă în audit, risc rezidual și acceptarea responsabilului.

REZULTAT PENTRU CLIENT

Sumar executiv + registru tehnic al constatărilor + listă de remediere prioritizată + observații de arhitectură + plan de validare + dovezi reutilizabile pentru închidere.